Cybersecurity Program - Personal Takeaways

Week 1: Foundations of Network Security

- I learned the basics of network security with things like how networks work, the OSI model, and identifying network vulnerabilities. This gave me a baseline for future cybersecurity concepts.
- Learning the fundamentals of what Linux is and does was important as it is the most used OS in the world
- Understanding how the filesystem works with auditing user privileges taught me about access controls and least privilege

Week 2: Advanced Linux and Windows Administration

- Introduced to compliance frameworks like PCI DSS, SOX, GLBA, and HIPPA were helpful given my interest in GRC and our work in the financial sector
- Securing user accounts and file permissions on a linux machine allowed me to get hands on experience with access controls and was beneficial given my interest in IAM
- Hardening a Windows server with things like Bitlocker encryption, gave me an idea into hardening other systems besides Linux ones, and using Microsoft security features

Week 3: Virtualization and Container Functions

- It was interesting to learn what hypervisors are and their applications. It was useful to learn about the underlying technology of the systems we're working with
- Specifically learning about lateral movement in virtualized environments as an attack type was important as this was a recurring exploit throughout our labs and in the news with the recent hacks we covered
- Learning about mitigations (vm isolation and hypervisor hardening) gave me a good idea of how to secure virtualization functions with defense in depth

Week 4: Network Security and Cryptography 101

- Building an internal Certificate Authority and configuring TLS gave me a hands on understanding of the chain of trust with website verification
- Investing misconfigured TLS showed me how outdated or broken security controls can give you a false sense of security, and allowing you to be susceptible to MITM attacks

- Understanding key cryptographic concepts like hashes and key encryption, was beneficial in connecting concepts like confidentiality, integrity, authentication, and non-repudiation

Week 5: Next Generation Firewalls

- Understanding that Next Generation Firewalls do deep packet inspection expanded my knowledge on what I already knew about traditional firewalls
- Learning that firewall rules are evaluated top-down- if match is found, following rules disregarded (if an overexposed rule on top of a stricter one, the overexposed one is met and the stricter is disregarded) gave me a clearer idea of how they work
- Regularly updating these firewall rules is a mitigation strategy was important to know as there are constantly emerging threats the original rules didn't consider

Week 6: Cybersecurity Threats and Vulnerabilities

- Differentiating the types of security controls- preventive, detective, and corrective gave me an overview on the different proactive response to different threats and vulnerabilities
- Learning the NIST CSF framework - Identify, Protect, Detect, Respond, Recover was beneficial in learning it can be used as a security assessment tool and posture roadmap
- Examining the MITTRE ATT@CK framework - tactics, techniques, procedures, helped me understand how attackers operate in the real world. The framework is also widely adopted in the industry so getting familiar with it was useful

Week 7: Security Operations, Incident Response and Integration of AI

- Learning what a SOC- security operations center, is and how they operate is important, as the SOC workflow and monitoring is a huge aspect of cybersecurity
- Comparing the tiers - 1,2,3, was interesting as I could see the different roles and responsibilities as each tier trades speed for depth going up.
- Working with SIEM- security information event management, logs and triaging them gave me hands on experience with SOC work and the incident response process

Week 8: SOC Tools and Data Analytics 101

- Getting familiar with Wireshark gave me practical experience with packet analysis and looking for IoCs via packet sniffing
- Going more in depth with SIEMs with tools like Splunk and Sentinel gave more a good idea of what analysts actually use in their workflows

- Understanding the workflow of the EDR watching the endpoint, the SIEM centralizing the information and alert, and SOAR and AI automating response actions and interpreting data gave me a clearer picture of how all these functions work together from a high level

Week 9: Power BI for Security and Fraud Analytics

- Learning how Power BI turns raw data into interactive dashboards and reports helped me understand how we can show granular metrics with clarity to stakeholders, management, and a non-technical audience.
- Diving deeper into Power BI, learning Power Query is a tool to help shape and clean our data was beneficial in having proper etiquette with our datasets before they're used for dashboards.
- Noting how DLP- data loss prevention policies in Power BI are tied to governance oversight set by the organization was useful. As someone interested in GRC and TPRM, this is something I would see often in my career.

Top 3 Quotes

“Document Throughout, Not at the End”

- Documentation should happen continuously during security investigations, incident response, and system changes
- Recording actions, evidence, timestamps, and decisions as they occur creates a reliable audit trail and improves accountability

“Humans Are the Weakest Link in Cybersecurity”

- Even organizations with advanced security controls can be compromised through human error
- Social engineering attacks, weak passwords, phishing interactions, and improper handling of sensitive information show why employee awareness and secure processes are essential

“Proactively plan, effectively execute”

- Strong security outcomes start before an incident occurs, with defined response plans, assigned roles, and tested procedures already in place
- Well-rehearsed plans let teams act quickly and confidently under pressure, reducing downtime, limiting damage, and avoiding costly improvised decisions

5 Topics That Interested Me

- Explored interest in GRC (PCI DSS, SOX, etc.) and TPRM (KY3P), especially in tabletop exercises
- Learning different social engineering tactics (phishing, pretexting, etc.), and how humans can be “hacked”
- Exploring the different roles and responsibilities that go into an effective incident response
- Utilizing different playbooks to escalate tickets in the lab where acted as SOC analysts
- Exploring what IAM does, and gaining experience with the active directory

7 Technical Topics I Didn’t Know Before

- A deeper dive into the OSI model
- A Comprehensive understanding of network protocols
- Type 1 and 2 hypervisors, and the differences between them
- Exposure to SIEMs and what they are
- Implementing PowerBI with security data to make dashboards
- MITTRE ATT@CK framework - TTP
- SOAR - Security, Orchestration, Automation, and Response
- Compliance Frameworks (PCI DSS, NIST, SOX, GLBA etc.)